

Security Governance & Goals

- **Confidentiality Violation:** Eavesdropping on wireless communications is a primary example of a confidentiality breach, as it involves unauthorized access to data.
- **Core Security Concepts:** The CIA Triad (Confidentiality, Integrity, and Availability) represents the fundamental goals and objectives of security.
- **Due Diligence vs. Due Care:** Due diligence refers to the research and planning for security, while due care is the actual implementation or "doing" of the right action.
- **Security Roles:** The Security Professional is the role with functional responsibility for writing and implementing security policies.
- **Alignment Framework:** ITIL is the framework used to align IT and security services with the specific objectives of an organization.

Risk Management & Analysis

- **Risk Identification:** A risk is the result of a threat (e.g., fire) exploiting a vulnerability (e.g., no extinguishers); in this scenario, the risk is damage to equipment.
- **Quantitative Risk Calculation:** To compute the Annualized Loss Expectancy (ALE), use the formula:
- $ALE = AV \times EF \times ARO$
- **(Where AV is Asset Value, EF is Exposure Factor, and ARO is Annualized Rate of Occurrence).**
- **Business Impact Analysis (BIA):** The very first step of the BIA process is the identification of priorities to determine which business functions are most critical.

Legal & Intellectual Property

- **Legal Categories:** The three primary categories of law in the U.S. legal system are Criminal, Civil, and Administrative.
- **Intellectual Property (IP):** A Utility Patent is the specific type of IP protection that grants an inventor rights for a period of 20 years.

Data Management & Protection

- **Data at Rest:** Information stored on physical media (HDD, SSD, tapes); protected primarily by **encryption**¹.
- **Pseudonymization:** Replaces data with artificial identifiers; unlike anonymization, this process is **reversible**².
- **Data Owner:** The person who classifies and labels data; they are responsible for its overall protection³.
- **Data Custodian:** The person delegated the day-to-day tasks of storing and protecting data⁴.
- **Record Retention:** A policy defining how long data is kept; failure to delete data according to this policy is a compliance failure⁵.
- **Software Escrow:** A third party holds source code to protect the buyer if the vendor goes bankrupt⁶.

Security Models & Architecture

- **Bell-LaPadula Model:** Focuses on confidentiality. Rules include **Simple Security** (No Read Up) and ***-Property** (No Write Down)⁷.
- **Trusted Computing Base (TCB):** The total combination of hardware, software, and controls that enforce security⁸.
- **Closed vs. Open Systems:** **Closed systems** are proprietary and non-interoperable;

Closed source means the code is hidden from the public⁹.

- **Hypervisors: Type I** runs directly on hardware (bare-metal); **Type II** runs as an application on a host OS¹⁰.
- **KISS Principle**: "Keep It Simple"—simpler systems are easier to secure and troubleshoot¹¹.
- **Zero Trust**: A concept where no entity (inside or outside) is trusted by default; everything is continuously validated¹².
- **Defense in Depth**: Using multiple security controls in **series** (layered security)¹³.

Cryptography & Secure Communication

- **Symmetric vs. Asymmetric**: Asymmetric is more **scalable** because public keys are shared easily; Symmetric requires a secure key exchange¹⁴.
- **Hashing**: Creates a fixed-size "fingerprint" (digest) used to verify **data integrity**¹⁵.
- **HTTPS**: Secure web traffic using **TLS** or SSL encryption¹⁶.
- **VPN**: Creates an **encrypted tunnel** for secure communication over untrusted networks like the internet¹⁷.

Network Security

- **Stateful Inspection Firewalls**: These track the **context/state** of sessions to make better filtering decisions¹⁸.
- **WPA3**: The current standard for Wi-Fi security, providing better protection against brute-force attacks¹⁹.
- **TCP/IP Internet Layer**: Handles IP addressing and **routing**²⁰.
- **DNS**: Translates human-friendly names (www.google.com) into numerical **IP addresses**²¹.
- **Routers**: Operate at **Layer 3** and are used to segment networks and separate broadcast domains²².

- **Intrusion Detection (IDS):** Monitors and reports malicious activity; **signature-based** systems look for known attack patterns²³.

Access Control & Identity Management

- **Least Privilege:** Users get only the **minimum access** needed for their job²⁴.
- **Privilege Escalation:** When a user gains more permissions than they are authorized to have²⁵.
- **SAML:** A standard for exchanging auth data, commonly used for **Single Sign-On (SSO)**²⁶.
- **Multi-Factor Authentication (MFA):** Requires 2+ factors (Something you **know, have, or are**)²⁷.
- **RBAC:** Access is based on the user's **role** within the organization²⁸.
- **TACACS+:** A centralized AAA protocol that **encrypts the entire packet body**²⁹.

Software Development & Operations

- **Secure Coding: Server-side validation** is critical to prevent attackers from bypassing client-side checks³⁰.
- **Fagan Inspection:** A highly formal code review process (Planning -> Overview -> Prep -> Inspection -> Rework -> Follow-up)³¹.
- **Fuzzing:** Sending random/invalid data to a program to find security bugs³².
- **DevOps:** Combines development and operations to shorten the life cycle and provide continuous delivery³³.
- **Cloud Shared Responsibility:** Defines which security tasks belong to the provider and which belong to the customer³⁴.
- **Change Management:** A formal process to ensure IT changes are controlled and documented³⁵.

Threats, Attacks, & Risk Management

- **Evil Twin:** A fraudulent Wi-Fi access point used to trick users and steal data³⁶.
- **Pretexting:** Creating a false story to manipulate someone into giving up info³⁷.
- **Whaling:** A phishing attack targeting **high-profile executives**³⁸.
- **SQL Injection:** Injecting malicious code into input fields to manipulate a database³⁹.
- **PASTA:** A threat modeling methodology; **Stage 1** defines the business objectives⁴⁰.
- **STRIDE:** A mnemonic for threats; **Information Disclosure** refers to unauthorized data exposure⁴¹.
- **Supply Chain Risk (SCRM):** Managing risks from third-party components that might be counterfeit or malicious⁴².

Business Continuity & HR Security

- **Nondisclosure Agreement (NDA):** A legal contract to ensure confidentiality⁴³.
- **Mandatory Vacations:** A control where another person does a user's job to help detect fraud⁴⁴.
- **Hot Site:** A fully equipped backup data center for **minimal downtime**⁴⁵.
- **Business Continuity Planning (BCP):** The process of identifying threats and planning how to keep the business running⁴⁶.
- **Employee Termination:** The most critical step is **immediately disabling all access**⁴⁷.

Security Actions

1. Governance, Risk, & Compliance (GRC)

- **Core Goals:** The CIA Triad (Confidentiality, Integrity, and Availability) defines the fundamental goals of security.
- **Planning vs. Action:** Due diligence is the research and planning phase; due care is the actual implementation of security measures.
- **Legal & IP:** The U.S. legal system uses Criminal, Civil, and Administrative law. A Utility Patent protects an inventor's rights for 20 years.
- **Risk Metrics:** Calculate the Annualized Loss Expectancy (ALE) by multiplying Asset Value (AV), Exposure Factor (EF), and Annualized Rate of Occurrence (ARO).
- **Business Impact:** The first step of a Business Impact Analysis (BIA) is identifying and prioritizing critical business functions.

2. Asset & Software Control

- **Hardware Inventory:** Actively track all devices (servers, IoT, mobile) using tools like DHCP logs and passive discovery to find unauthorized assets weekly.
- **Software Hygiene:** Only run authorized and supported software. Use allowlisting to prevent unauthorized applications, libraries, or scripts from executing.
- **Secure Config:** Disable default accounts, enforce session locking after inactivity, and use secure protocols like SSH and HTTPS for management.

3. Data Protection & Recovery

- **Classification:** Label data (e.g., Sensitive, Confidential, Public) to define how it should be handled throughout its lifecycle.
- **Encryption:** Use strong encryption (like AES-256) for data at rest on servers and TLS 1.3 for data in transit.
- **Lifecycle:** Implement Record Retention policies to define how long data is kept and ensure it is securely disposed of once that time expires.
- **Backups:** Follow the 3-2-1 rule (3 copies, 2 media types, 1 offsite). Ensure backups are encrypted, isolated (air-gapped), and tested quarterly.

4. Identity & Network Security

- **Access Principles:** Least Privilege ensures users only have the minimum access needed for their role. RBAC (Role-Based Access Control) simplifies this by grouping permissions by role.
- **Authentication:** Multi-Factor Authentication (MFA) should be mandatory for all external, administrative, and remote access.
- **Network Defense:** Segment the network using VLANs and DMZs to isolate traffic. Use Stateful Inspection Firewalls to filter traffic based on context and VPNs to create secure tunnels over untrusted networks.

5. Vulnerability & Monitoring

- **Vulnerability Management:** Perform automated scans quarterly (internal) and monthly (external). Remediate high-risk findings within 7 days.
- **Logging:** Centralize all audit logs in a SIEM (Security Information and Event Management) system. Retain logs for at least 90 days and review them weekly for anomalies.
- **Detection:** Use IDS/IPS (Intrusion Detection/Prevention) at the network level and HIDS/EDR at the host level to monitor for malicious patterns.

6. Threats, Software, & Incidents

- **Common Attacks:**
 - **Social Engineering:** Includes Phishing (email), Whaling (targeting executives), and Pretexting (manipulative stories).
 - **Technical:** SQL Injection exploits database vulnerabilities; Evil Twins are fake Wi-Fi hotspots.
- **Secure Software:** Integrate security into the entire SDLC (Software Development Life Cycle). Use threat modeling (like STRIDE) before coding and SAST/DAST tools for security checks.
- **Incident Response:** Follow a formal process (like NIST 800-61) involving Preparation, Detection, Containment, Eradication, Recovery, and Post-Incident reviews.
- **Third Parties:** Maintain an inventory of service providers, classify them by risk, and require them to report incidents within 24–72 hours.

Jobs and Roles Responsibilities

1. Identity and Access Management (IAM)

- **In Charge Of:** Managing the full account lifecycle (onboarding to termination), implementing Single Sign-On (SSO), and ensuring Multi-Factor Authentication (MFA) is mandatory for all administrative and remote access.
- **Role Responsibilities:** You must centralize access control through directory services and immediately revoke access upon an employee's termination.
- **Exam "Need to Know":**
 - **Least Privilege:** Granting only the minimum access needed for a job.
 - **RBAC:** Assigning access based on a user's role rather than individual identity.
 - **SAML:** The standard for exchanging auth data in web-based SSO.
 - **TACACS+:** Encrypts the entire body of the packet (unlike RADIUS).

2. Network Security Architecture

- **In Charge Of:** Designing a segmented network using VLANs to separate user, management, and critical asset traffic.
- **Role Responsibilities:** Managing secure connectivity (VPNs) for remote devices and maintaining up-to-date network architecture diagrams.
- **Exam "Need to Know":**
 - **OSI Layer 3:** Where routers operate to separate broadcast domains and segment networks.
 - **TCP/IP Internet Layer:** Responsible for logical addressing (IP) and routing.
 - **DNS:** Hierarchical system translating domain names to IP addresses.

3. Perimeter Defence and Threat Detection

- **In Charge Of:** Implementing layered defenses like Next-Generation Firewalls (NGFW) and IDS/IPS at the network perimeter.
- **Role Responsibilities:** Configuring DNS filtering to block malicious domains and DMARC/SPF/DKIM for email security.
- **Exam "Need to Know":**
 - **Stateful Inspection:** Firewalls that evaluate the context/state of a session, not just individual packets.
 - **Signature-based IDS:** Looks for known attack patterns.
 - **Defense in Depth:** Using multiple controls in series (layered) rather than parallel.

4. Data Security and Encryption

- **In Charge Of:** Establishing a Data Classification Scheme (e.g., Sensitive, Confidential, Public) and ensuring encryption at rest and in transit.
- **Role Responsibilities:** Automating Data Loss Prevention (DLP) to monitor for unauthorized data movement.
- **Exam "Need to Know":**
 - **Data Owner:** Responsible for classifying and labeling data.
 - **Data Custodian:** Responsible for the day-to-day storage and protection tasks.
 - **Hashing:** Used to ensure integrity by producing a fixed-size fingerprint of a file.
 - **Asymmetric Cryptography:** Highly scalable because public keys can be shared freely.

5. Endpoint Security

- **In Charge Of:** Deploying EDR and anti-malware (e.g., Microsoft Defender) across all user devices.
- **Role Responsibilities:** Using Mobile Device Management (MDM) to separate enterprise workspaces from personal data on mobile devices.
- **Exam "Need to Know":**
 - **Allowlisting:** The most effective way to ensure only authorized software executes.
 - **WPA3:** The latest Wi-Fi standard providing stronger encryption and brute-force protection.
 - **Evil Twin:** A fake Wi-Fi access point used to monitor user traffic.

6. Cloud Security Architecture

- **In Charge Of:** Managing security across IaaS, PaaS, and SaaS using tools like CASB and CSPM.
- **Role Responsibilities:** Implementing the Shared Responsibility Model to define security duties between the provider and customer.
- **Exam "Need to Know":**
 - **Hypervisors:** Type I (bare-metal) runs directly on hardware; Type II runs on a host OS.
 - **Zero Trust:** Never trust by default; always authenticate, authorize, and encrypt every request.

7. Application Security

- **In Charge Of:** Integrating security into the Software Development Lifecycle (SDLC) through SAST/DAST testing.
- **Role Responsibilities:** Scanning third-party components for vulnerabilities and enforcing secure coding standards.

- Exam "Need to Know":
 - SQL Injection: Attacker uses malicious SQL statements in input fields to manipulate the database.
 - Software Escrow: Protects the buyer if the software vendor goes out of business.
 - Fuzzing: Sending random/invalid data to an app to find security flaws.

8. Security Operations and Monitoring (SOC)

- In Charge Of: Centralizing all logs (DNS, URL, Auth) into a SIEM for 24/7 monitoring.
- Role Responsibilities: Conducting weekly log reviews to detect anomalies and responding to security alerts.
- Exam "Need to Know":
 - NIST 800-61: The standard framework for the Incident Response process.
 - Time Synchronization: All logs must use standardized time (NTP) for accurate forensic correlation.

9. Governance, Risk, and Compliance (GRC)

- In Charge Of: Developing policies, performing Risk Assessments, and managing Vendor Risk (SCRM).
- Role Responsibilities: Conducting security awareness training and enforcing Mandatory Vacations to detect internal fraud.
- Exam "Need to Know":
 - ALE (Annualized Loss Expectancy): Calculated as $\text{Asset Value} \times \text{Exposure Factor} \times \text{Annualized Rate of Occurrence}$.
 - STRIDE: A threat modeling mnemonic (Spoofing, Tampering, Repudiation, Info Disclosure, DoS, Elevation of Privilege).
 - Due Diligence vs. Due Care: Due diligence is the research/planning; due care is the implementation of correct actions.

10. Business Continuity and Disaster Recovery (BCDR)

- **In Charge Of:** Designing backup strategies using the 3-2-1 rule and establishing an isolated (air-gapped) instance of recovery data.
- **Role Responsibilities:** Testing backup recovery quarterly and maintaining Disaster Recovery Plans with defined RTO/RPO.
- **Exam "Need to Know":**
 - **Business Impact Analysis (BIA):** The first step is identifying priorities for business functions.
 - **Recovery Sites:** Hot sites (fully equipped, ready immediately) vs. Cold sites (empty shell).

Foundational Principles

Before the pillars, the framework relies on two core security mindsets:

- **Defense in Depth:** The use of multiple, layered security controls in **series**¹¹¹. Because no single control can stop all threats, layers provide the necessary resilience².
+2
- **Zero Trust:** A modern concept where nothing inside the organization is trusted by default³³³³. Every request for access must be **authenticated, authorized, and encrypted**⁴.
+2

Pillar I: Strategy & Governance

This pillar focuses on managing risk and establishing the legal/policy framework for security⁵.

- **Risk Analysis:**
 - **Quantitative:** Assigns real dollar figures to asset loss using mathematical formulas, such as **ALE = SLE × ARO** (Annualized Loss Expectancy = Single Loss Expectancy × Annualized Rate of Occurrence)⁶⁶⁶⁶.
+1
 - **Qualitative:** Assigns subjective/intangible values based on feelings and intuition to prioritize risks that are hard to quantify⁷⁷⁷⁷.
+1
- **Legal Mandates:**
 - **Due Diligence:** The **planning** phase—establishing policies and processes to protect the organization⁸.
 - **Due Care:** The **action** phase—doing the "right thing" by implementing the protection plan at the right time⁹.
- **Hierarchy of Directives:**
 - **Policies:** High-level, mandatory documents stating security goals (e.g., Acceptable Use Policy)¹⁰¹⁰¹⁰¹⁰.
+1
 - **Standards:** Mandatory, specific rules for consistency (e.g., "All servers must use AES-256")¹¹¹¹¹¹¹¹.
+1

- **Guidelines:** Recommended but non-mandatory best practices (e.g., how to choose a strong password)¹²¹²¹²¹².

+1

Pillar II: Protecting Core Assets

This pillar centers on protecting data based on its state and using physical/logical barriers¹³¹³¹³¹³.

+1

- **States of Data:**

- **Data in Use:** Active in memory (RAM); the most vulnerable state, protected by access controls¹⁴.
- **Data at Rest:** Stored on media (Hard drives, SSDs); protected by strong **symmetric encryption**¹⁵.
- **Data in Motion:** Transmitted over a network; protected by protocols like **TLS and VPNs**¹⁶.

- **Cryptography Fundamentals:**

- **Symmetric (AES):** One shared key; fast; used for bulk encryption¹⁷.
- **Asymmetric (RSA):** Public/private key pair; slower; used for digital signatures and key exchanges¹⁸.
- **Hashing:** A one-way function used to create a unique digest for integrity checks¹⁹.

- **Isolation & Barriers:**

- **Logical Isolation:** Using **hypervisors (VMM)** to create virtual machines that isolate guest operating systems from each other²⁰²⁰²⁰²⁰.

+1

- **Physical Fortification:** Includes fences, guards, and environmental controls like **FM-200 fire suppression** and HVAC²¹²¹²¹²¹.

+1

Pillar III: Securing Connectivity

Connectivity focuses on network design and traffic control to prevent lateral movement by attackers²²²²²²²².

+1

- **Network Segmentation:** Dividing the network into smaller zones using **routers, firewalls, and VLANs**²³. This contains breaches and is a core part of **Zero Trust**²⁴.
+1
- **Firewall Evolution:**
 - **Static Packet Filtering:** Basic rules based on IP/Port; stateless²⁵.
 - **Stateful Inspection:** Tracks the state of connections to add context to decisions²⁶.
 - **Next-Generation Firewall (NGFW):** Adds application awareness, **IPS**, and **Deep Packet Inspection (DPI)** to analyze the payload, not just headers²⁷.
- **Secure Protocols:**
 - **HTTPS (HTTP over TLS):** Standard for web communication; ensures confidentiality and integrity²⁸.
 - **VPN:** Creates an encrypted tunnel over untrusted networks (like the internet) for remote access²⁹.

Pillar IV: The Human Element

While the provided text focuses heavily on the technical pillars, the framework identifies the "Human Element" as the final pillar³⁰.

- **Exam Context:** This pillar typically involves **Security Awareness Training** to defend against social engineering (phishing, pretexting) and ensuring that employees understand their role in the security architecture.